SPURVANCE LABS

Lab 2

System Hardening & Access Control

Firewall Configuration with UFW: Allow-List of SSH, HTTP and HTTPS

Report Title	Lab 2 – System Hardening & Access Control
Organisation	Spurvance Labs
Prepared by	Muhammad Saad Shakeel
Date	21/10/2026
Lab Environment	Kali Linux
Tool Used	UFW (Uncomplicated Firewall)
Classification	Internal – Training Use

Table of Contents

1. Executive Summary....3
2. Objectives....3
3. Scope & Environment....3
4. Firewall Policy Summary....4
5. Implementation....4
Step 1 – Install UFW....4
Step 2 – Set Default Policies....5
Step 3 – Allow Essential Services....6
Step 4 – Enable the Firewall....6
6. Verification....7
6.1 Firewall Status....7
6.2 Listening Sockets (ss)....7
6.3 Numbered Rule List....8
6.4 Blocked-Port Test....8
6.5 Expected Results....9
7. Rule Rationale....9
8. Lab Safety & Rollback....9
9. Security Considerations & Recommendations....10
10. Conclusion....10

1. Executive Summary

This lab implements a host-based firewall on a Kali Linux system using UFW. The objective was to reduce the system's attack surface by applying a default-deny policy for inbound traffic and explicitly permitting only the three services required for secure administration and web delivery: SSH (22/tcp), HTTP (80/tcp) and HTTPS (443/tcp).

All other inbound ports are blocked by default. Outbound traffic remains unrestricted so the host can receive updates and reach external services. The configuration was applied, enabled, and verified using UFW status output, a local socket review with ss, and an external port scan confirming that all non-essential ports are blocked.

2. Objectives

- Install and enable UFW on the lab host.
- Apply a default-deny policy for all incoming traffic.
- Allow only SSH (22), HTTP (80) and HTTPS (443).
- Verify the active rule set and confirm which services are listening.
- Prove that all other inbound ports are blocked by testing from a second machine.
- Apply the lab safely (isolated VM, SSH allowed first) and document how to roll back.
- Document each rule and the security reasoning behind it.

3. Scope & Environment

Item	Detail
Target system	Single Kali Linux lab VM (Debian-based)
Privileges	Administrative access via sudo
Network	Isolated lab network; no production systems affected
In scope	Inbound filtering of TCP services on the host
Out of scope	Network perimeter firewalls, IDS/IPS, application-layer filtering

4. Firewall Policy Summary

The policy follows the principle of least privilege: deny everything by default and permit only what is required.

Direction	Port / Protocol	Action	Purpose
Incoming	Default	**DENY**	Block all unsolicited inbound traffic
Outgoing	Default	**ALLOW**	Permit updates, DNS and outbound connections
Incoming	22/tcp	**ALLOW**	SSH – secure remote administration
Incoming	80/tcp	**ALLOW**	HTTP – web traffic
Incoming	443/tcp	**ALLOW**	HTTPS – encrypted web traffic

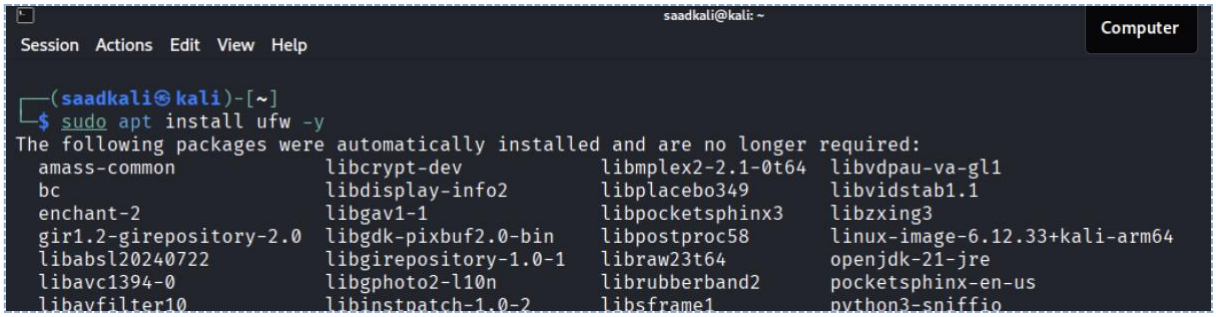
5. Implementation

Each step below lists the command executed and its effect. Insert the matching screenshot in the space provided.

Step 1 – Install UFW

Installs the Uncomplicated Firewall front-end for the kernel's netfilter framework.

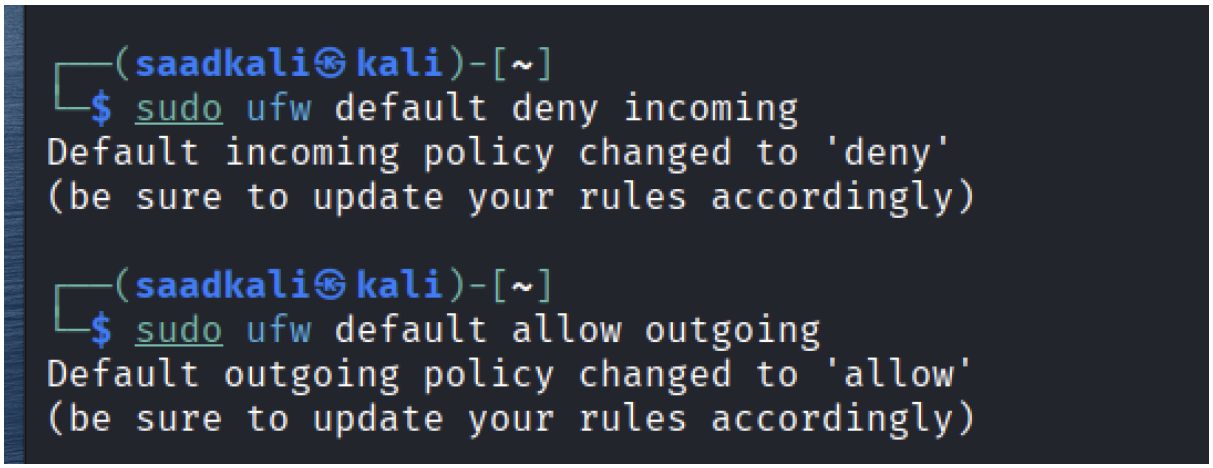
```
sudo apt install ufw -y
```



Step 2 – Set Default Policies

Default-deny for incoming traffic ensures that any port not explicitly opened is unreachable. Default-allow for outgoing traffic keeps the host functional for package updates and name resolution.

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
```



Step 3 – Allow Essential Services

Only the required services are opened, restricted to TCP. SSH is allowed before the firewall is enabled so that the remote session is not interrupted.

```
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
```

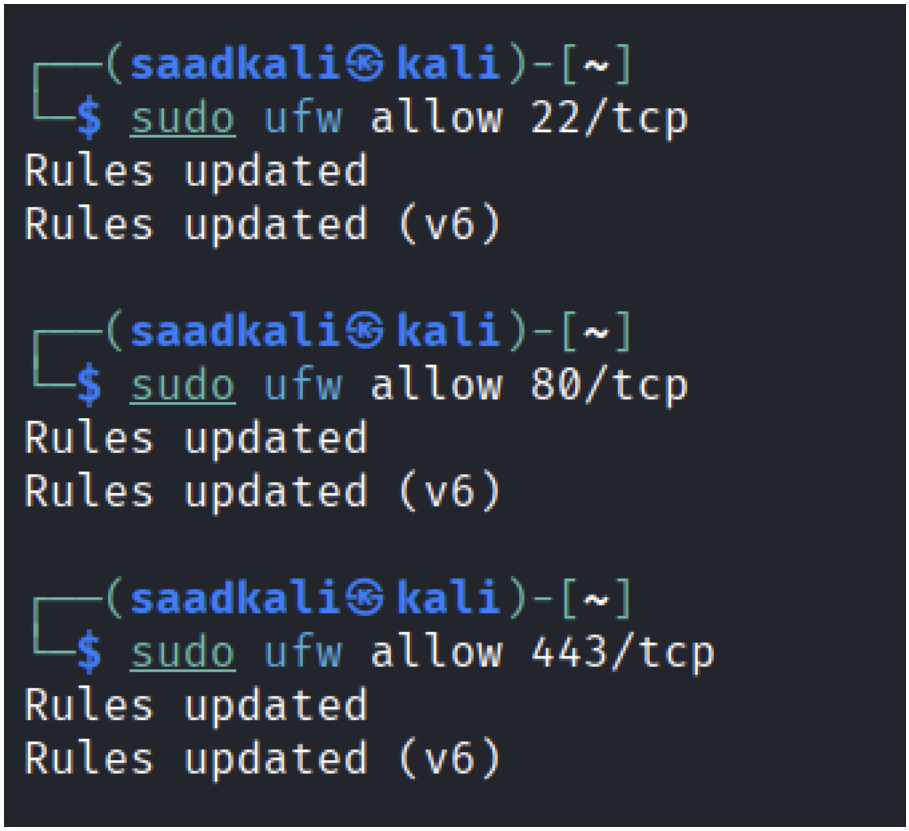


Figure 3 – Allow rules added

Step 4 – Enable the Firewall

Activates the rule set immediately and configures UFW to start automatically at boot.

```
sudo ufw enable
```

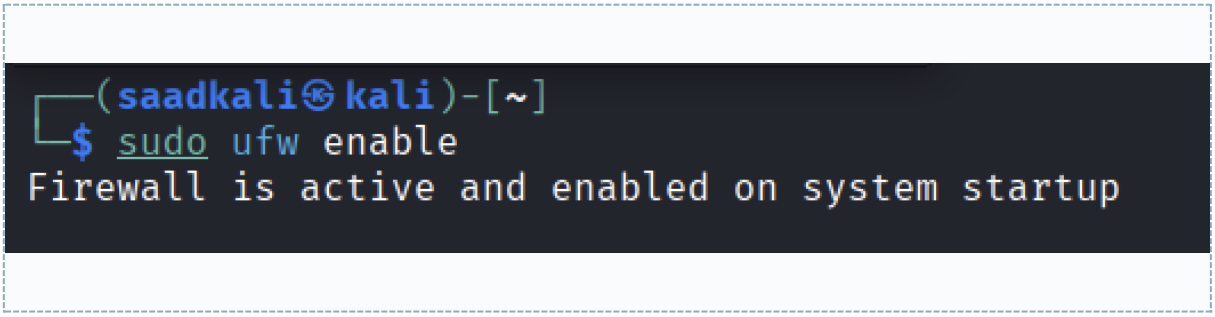


Figure 4 – UFW enabled

6. Verification

6.1 Firewall Status

The verbose status output confirms the firewall is active, shows the default policies, and lists all permitted rules.

```
sudo ufw status verbose
```

```
┌──(saadkali㉿kali)-[~]
└─$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW IN    Anywhere
80/tcp                     ALLOW IN    Anywhere
443/tcp                    ALLOW IN    Anywhere
22/tcp (v6)                ALLOW IN    Anywhere (v6)
80/tcp (v6)                ALLOW IN    Anywhere (v6)
443/tcp (v6)               ALLOW IN    Anywhere (v6)
```

Figure 5 – UFW status (verbose)

6.2 Listening Sockets (ss)

The ss utility lists services currently listening on the host. This confirms which ports are in use and helps ensure no unexpected service is exposed behind the firewall.

```
sudo ss -tuln
sudo ss -tulpn
```

```
┌──(saadkali㉿kali)-[~]
└─$ sudo ss -tuln
[sudo] password for saadkali:
Netid     State      Recv-Q     Send-Q                                  Local Address:Port          Peer Address:Port
udp       UNCONN     0          0                                        192.168.64.3:68               0.0.0.0:*
udp       UNCONN     0          0                [fdd1:b677:27a7:4bd3:ac42:cfff:fe4e:7fcc]:546             [::]:*
udp       UNCONN     0          0                [fdd1:b677:27a7:4bd3:b2b3:9a02:610b:6395]:546             [::]:*
udp       UNCONN     0          0                           [fe80::9748:7518:4da:39fa]%eth0:546             [::]:*

┌──(saadkali㉿kali)-[~]
└─$ sudo ss -tulpn
Netid State  Recv-Q Send-Q                                Local Address:Port Peer Address:PortProcess
udp   UNCONN 0      0                                      192.168.64.3:68       0.0.0.0:*    users:(("dhcpcd",pid=1017,fd=4))
udp   UNCONN 0      0      [fdd1:b677:27a7:4bd3:ac42:cfff:fe4e:7fcc]:546          [::]:*    users:(("dhcpcd",pid=2337,fd=4))
udp   UNCONN 0      0      [fdd1:b677:27a7:4bd3:b2b3:9a02:610b:6395]:546          [::]:*    users:(("dhcpcd",pid=925,fd=4))
udp   UNCONN 0      0                 [fe80::9748:7518:4da:39fa]%eth0:546          [::]:*    users:(("dhcpcd",pid=726,fd=4))
```

Figure 6 – Listening ports reviewed with ss

6.3 Numbered Rule List

A numbered listing makes each rule easy to reference, audit or delete individually.

```
sudo ufw status numbered
```

```
┌──(saadkali㉿kali)-[~]
└─$ sudo ufw status numbered
Status: active

     To                         Action      From
     --                         ------      ----
[ 1] 22/tcp                     ALLOW IN    Anywhere
[ 2] 80/tcp                     ALLOW IN    Anywhere
[ 3] 443/tcp                    ALLOW IN    Anywhere
[ 4] 22/tcp (v6)                ALLOW IN    Anywhere (v6)
[ 5] 80/tcp (v6)                ALLOW IN    Anywhere (v6)
[ 6] 443/tcp (v6)               ALLOW IN    Anywhere (v6)
```

Figure 7 – Numbered rule list

6.4 Blocked-Port Test

To prove that everything outside the allow-list is blocked, scan the lab host from a second machine on the same isolated network. Scanning from the host itself is not a valid test, because loopback traffic is always permitted. Replace <LAB-IP> with the address shown by ip a on the Kali VM.

```
nmap -Pn -p 21,22,23,80,443,3389,8080 <LAB-IP>
```

```
Last login: Wed Oct 21 07:54:33 on console
(base) saad@Muhammads-MacBook-Air ~ %
(base) saad@Muhammads-MacBook-Air ~ % nmap -Pn -p 21,22,23,80,443,3389,8080 192.
168.64.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-10-21 09:53 +0400
Nmap scan report for 192.168.64.3
Host is up (1.0s latency).

PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   closed   ssh
23/tcp   filtered telnet
80/tcp   closed   http
443/tcp  closed   https
3389/tcp filtered ms-wbt-server
8080/tcp filtered http-proxy

Nmap done: 1 IP address (1 host up) scanned in 12.95 seconds
(base) saad@Muhammads-MacBook-Air ~ %
```

Figure 8 – Port scan from a second machine

An Nmap TCP port scan was performed from the MacBook Air against the Kali Linux VM at 192.168.64.3, targeting ports 21, 22, 23, 80, 443, 3389, and 8080.

Ports 21, 23, 3389, and 8080 were reported as filtered, indicating that Nmap could not determine whether these ports were open because probes or responses were being filtered. Ports 22, 80, and 443 were reported as closed, indicating that no service was accepting connections on those ports at the time of testing.

The results are consistent with the configured default-deny incoming firewall policy. The allowed ports were not reported as open because the corresponding services may not be running.

6.5 Expected Results

Check	Expected Outcome
Firewall state	Status: active
Default policy	deny (incoming), allow (outgoing)
Allowed ports	22/tcp, 80/tcp, 443/tcp (IPv4 and IPv6)
All other inbound ports	Blocked shown as filtered in the nmap scan

7. Rule Rationale

Rule	Why it is needed
`Default deny incoming`	Establishes a secure baseline. New or forgotten services are not exposed unless deliberately allowed.
`Default allow outgoing`	Allows the host to download updates and make DNS or API requests without maintaining a large outbound rule set.
`22/tcp (SSH)`	Required for encrypted remote administration. Without it, managing a headless server would not be possible.
`80/tcp (HTTP)`	Allows standard web requests and HTTP-to-HTTPS redirects, and is often needed for certificate validation.
`443/tcp (HTTPS)`	Provides encrypted web traffic, protecting data in transit from interception.

8. Lab Safety & Rollback

This lab was designed to be safe to build and easy to undo.

- **Isolated environment:** all work was done on a disposable Kali Linux VM, not on a production or personal system.
- **Snapshot first:** take a VM snapshot before enabling the firewall so the original state can be restored instantly.
- **Avoid lockout:** the SSH rule (22/tcp) is added before ufw enable, so a remote session is not cut off.
- **Console access:** keep local VM console access available in case a rule is misconfigured.

Rollback action	Command
Delete a single rule	`sudo ufw delete allow 80/tcp`
Temporarily disable firewall	`sudo ufw disable`
Reset all rules to default	`sudo ufw reset`

9. Security Considerations & Recommendations

- **Restrict SSH further:** limit access to trusted IP ranges (e.g. sudo ufw allow from <trusted-IP> to any port 22) once the lab is stable.
- **Harden SSH:** disable password logins, use key-based authentication and disallow direct root login.
- **Rate-limit SSH:** use sudo ufw limit 22/tcp to slow brute-force attempts.
- **Enable logging:** sudo ufw logging on provides an audit trail of blocked connections.
- **Close unused services:** if the host does not serve web content, remove the 80/443 rules to keep the allow-list minimal.
- **Review regularly:** re-run ufw status and ss after any software change to confirm the exposed surface has not grown.

10. Conclusion

The firewall was configured with a default-deny inbound policy and a minimal allow-list of SSH, HTTP and HTTPS. This reduces the host's exposure to unsolicited network traffic while preserving the services required for administration and web access. The configuration was verified with UFW status output, a socket review using ss, and a port scan from a second machine, and it aligns with the least-privilege principle fundamental to system hardening.